

Pterodactyl - Penetration Test Report

1. Executive Summary

During the security assessment of the **Pterodactyl** infrastructure, a chain of vulnerabilities was identified within a web management platform that allowed for unauthorized information disclosure and eventual system compromise. The attack path involved exploiting an arbitrary file read vulnerability (CVE-2025-49132) in the Pterodactyl Panel, leveraging a PHP Local File Inclusion (LFI) to achieve Remote Code Execution (RCE) via PEAR, and finally exploiting a race condition in the `udisksd` daemon to gain full root access on the underlying openSUSE Linux host.

2. Technical Findings and Exploitation

2.1 Information Disclosure: Arbitrary File Read (CVE-2025-49132)

Severity: High

- **Observation:** The Pterodactyl Panel (v1.11.10) was found to be vulnerable to an arbitrary file read vulnerability.
- **Impact:** This allowed for the extraction of sensitive backend configuration files and environment variables.
- **Exploitation:** By targeting the `/locales/locale.json` endpoint with specific namespace parameters, the `config/database` file was retrieved. This revealed cleartext MariaDB credentials: `pterodactyl:PteraPanel`.
- **Remediation:** Update the Pterodactyl Panel to a patched version and ensure that file-system access via API endpoints is strictly restricted to intended directories.

2.2 Remote Code Execution (RCE): PHP LFI via PEAR

Severity: Critical

- **Observation:** The application's file inclusion capabilities were leveraged to interact with the PEAR (PHP Extension and Application Repository) management tool.
- **Impact:** Full system compromise under the context of the web server user (`wwwrun`).
- **Exploitation:**
 1. **Stage 1:** A `curl` request used `pearcmd` to create a malicious configuration file at `/tmp/shell.php` containing a reverse shell payload.
 2. **Stage 2:** A second request included the newly created `/tmp/shell.php` file, executing the PHP code and establishing a reverse shell to the attacker's machine.

- **Remediation:** Disable the `register_argc_argv` PHP setting to prevent command-line argument injection into PHP scripts and remove or restrict access to `pearcmd.php`.

3. Privilege Escalation

3.1 Information Disclosure: Internal System Mail

Severity: Low/Medium

- **Observation:** After gaining initial access, the `/var/spool/mail` directory was found to be world-writable.
- **Impact:** Internal system notifications revealed that the `udisks` daemon required urgent security updates.
- **Remediation:** Restrict permissions on system mail directories and ensure internal security warnings are not accessible to unprivileged users.

3.2 Local Privilege Escalation: `udisksd` Race Condition (CVE-2025-6018/6019)

Severity: Critical

- **Observation:** The system was running an outdated version of `udisks2` (v2.9.2) on openSUSE Leap 15.6.
- **Exploitation:** A local exploit script targeted a race condition in the daemon's handling of XFS filesystem resizing.
- **Result:** The exploit successfully bypassed local security controls, granting full root access (EUID 0).
- **Remediation:** Establish a regular patch management schedule to update `udisks2` and other system daemons to the latest stable versions.

4. Remediation Summary

Finding	Severity	Recommendation
Arbitrary File Read	High	Update Pterodactyl Panel; restrict API filesystem access.
PEAR LFI to RCE	Critical	Disable <code>register_argc_argv</code> ; restrict or delete <code>pearcmd.php</code> .
World-Writable Mail	Medium	Correct permissions on <code>/var/spool/mail</code> to prevent info leaks.

Finding	Severity	Recommendation
udisksd Vulnerability	Critical	Update <code>udisks2</code> and the openSUSE system to the latest patched versions.